NODEJS Mistral Manual Code Review

Vulnerability X

CWE-200: Exposure of Sensitive Information
Generic returning of unsensitized errors directly to the client present in all of these systems.

Location: request-service/src/services/request.service.ts
logger.error(`Failed to send notification for new request: ${err}`);

logger.error(`Failed to add approved book to collection: ${err}`);

logger.error(`Failed to send decision notification: ${err}`);

1. Logging raw errors

logger.error(`Failed to retry notification ${notification.id}: ${err}`);

2. Storing raw errors in DB

```
await this.notificationRepository.updateNotificationFailure(
  notification.id!,
  `Retry failed: ${err}`
);
```

Vulnerability 1

CWE-287: Improper Authentication
Location: request-service/src/services/request.service.ts

Evidence:

await axios.post(`${env.NOTIFICATION_SERVICE_URL}/api/notifications`, {

await axios.post(`${env.BOOK_SERVICE_URL}/api/books`, {

The request service makes service-to-service calls to the notification-service and book-service without including an authentication mechanism such as an API key, JWT, or service identity. This weakens trust boundaries between microservices.

Vulnerability 2

CWE-284: Improper Access Control
Location: notification-service/src/services/notification.service.ts

Evidence:

async sendNotification(notificationRequest: NotificationRequestDTO)

The notification service processes and sends notifications using fully client-controlled input fields (recipient, subject, message, metadata) without performing any authorization checks. There is no validation of caller role, ownership, or allowed notification types.

Vulnerability 3 (confirmed)

CWE-287: Improper Authentication
Location: notification-service/src/services/notification.service.ts

Evidence:

await axios.post(`${env.NOTIFICATION_SERVICE_URL}/api/notifications`, {...})

and

async sendNotification(notificationRequest: NotificationRequestDTO)

The notification service does not enforce authentication for internal service-to-service communication. Requests can be made without API keys, JWT validation, or service identity verification.